

Clase 304 — Preparación CISSP: los 8 dominios

Parte: **16 — Capstones y preparación de certificaciones** · Fuente: *(ISC)² CISSP Official Study Guide (Chapple, Stewart, Gibson)* 🕒 Duración estimada: **120 min** · Nivel: **Avanzado**

🎯 Objetivo

Que el alumno obtenga un **mapa completo de los 8 dominios del CISSP**, entienda su peso relativo en el examen y la mentalidad "manager" que exige (pensar en riesgo y negocio antes que en la solución técnica), y elabore un **plan de estudio** con autoevaluación por dominio. El CISSP valida la capacidad de **diseñar y gestionar** un programa de seguridad, no de explotar sistemas.

📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

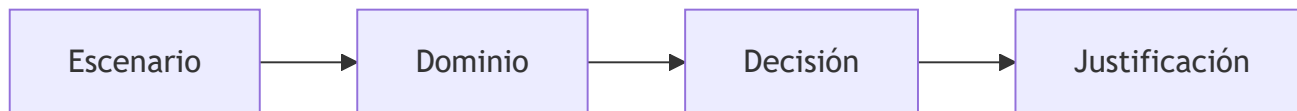
- 1. **Enumerar** los 8 dominios del CBK y su peso porcentual aproximado.
- 2. **Explicar** la mentalidad "think like a manager" del examen.
- 3. **Mapear** cada dominio a las partes del programa que lo sustentan.
- 4. **Autoevaluar** su nivel por dominio con una matriz de brechas.
- 5. **Diseñar** un plan de estudio de 3–6 meses con hitos.

📖 Temas

#	Tema	Por qué importa
1	D1 Seguridad y gestión de riesgos (~15%)	Gobierno, cumplimiento, ética
2	D2 Seguridad de activos (~10%)	Clasificación y ciclo de vida de datos
3	D3 Arquitectura e ingeniería (~13%)	Modelos, cripto, seguridad física
4	D4 Seguridad de redes y comunicaciones (~13%)	Diseño de red seguro
5	D5 Gestión de identidad y acceso (~13%)	IAM, autenticación, autorización
6	D6 Evaluación y pruebas de seguridad (~12%)	Auditoría, pentest, métricas
7	D7 Operaciones de seguridad (~13%)	IR, DR, BCP, forense
8	D8 Seguridad en el desarrollo de software (~11%)	SDLC seguro, DevSecOps

💬 Explicación en profundidad

CISSP evalúa razonamiento transversal de gestión y arquitectura; memorizar términos sin distinguir dueño, riesgo y ciclo de vida produce respuestas frágiles. La clase convierte el objetivo en una evidencia evaluable, declara supuestos y reserva tiempo para revisión. El resultado profesional incluye lo que no se comprobó.



Caso razonado

Una opción técnica parece más fuerte, pero contradice seguridad física y continuidad. La decisión integra dominios y prioridad de negocio.

Glosario operativo

Término	Definición
CBK	Cuerpo de conocimiento, no sustituto del esquema oficial vigente.
Evidencia	Resultado que otra persona puede revisar y relacionar con un criterio.
Retrospectiva	Revisión de decisiones, límites y siguiente mejora.

Criterio de dominio

El alumno domina la clase cuando planifica, ejecuta y comunica una evidencia completa, respeta alcance y puede defender sus decisiones ante una revisión.

Definiciones y características

- **CBK (Common Body of Knowledge):** temario canónico de (ISC)². *Característica:* organizado en 8 dominios con pesos definidos.
- **CAT (Computer Adaptive Testing):** formato del examen en inglés (100–150 preguntas). *Característica:* la dificultad se adapta a tus respuestas.
- **Due care vs due diligence:** cuidado razonable frente a investigación previa. *Característica:* concepto clave y muy preguntado.
- **Risk = amenaza × vulnerabilidad × impacto:** fórmula conceptual de riesgo. *Característica:* base del D1.
- **Defense in depth:** capas de control redundantes. *Característica:* principio transversal a todos los dominios.
- **Endorsement:** aval de 5 años de experiencia tras aprobar. *Característica:* sin él, quedas como *Associate of (ISC)²*.

Herramientas y preparación (ejercicio de GRC)

No hay laboratorio técnico; el trabajo es de **estudio y autoevaluación**:

- Guía oficial (*CISSP Official Study Guide*) y práctica de preguntas (bancos oficiales).
- Una hoja de cálculo para la matriz de brechas por dominio.
- Mapas mentales por dominio (herramienta como XMind o papel).
- Tu registro de progreso de las Partes 1–15 para el mapeo.

Laboratorio guiado (ejercicio aplicado)

1. **Construye la tabla de los 8 dominios** con su peso porcentual y 3 subtemas clave de cada uno.
2. **Mapea a tu programa.** Ejemplo: D4 ↔ Partes 2–3 (redes), D6 ↔ Partes 6–9 (testing), D7 ↔ Partes 10–13 (Blue Team/DFIR), D8 ↔ Parte 14 (DevSecOps).
3. **Autoevalúate.** Para cada dominio, puntúa tu dominio de 1 a 5 y anota la brecha.
4. **Practica la mentalidad manager.** Toma 5 preguntas de práctica y, para cada una, pregúntate: "¿cuál es la respuesta **de gestión de riesgo**, no la técnica inmediata?".
5. **Estudia due care/due diligence** y redacta un ejemplo propio de cada uno.
6. **Diseña el plan.** Asigna semanas por dominio priorizando tus brechas mayores.
7. **Simula.** Haz un test de práctica de 50 preguntas y calcula tu porcentaje por dominio.

Ejercicios

1. Escribe la tabla de dominios con pesos y subtemas.
2. Explica con tus palabras la diferencia entre *due care* y *due diligence*.
3. Mapea los 8 dominios a las partes del programa.
4. Resuelve 20 preguntas de práctica y clasifica tus fallos por dominio.
5. Redacta una política de clasificación de datos (D2) de una página.
6. Diseña una matriz de riesgo simple (probabilidad × impacto) para un activo.

Reto verificable

Entrega una **matriz de preparación CISSP** (`plan-cissp.md`) con: los 8 dominios, tu autoevaluación (1–5) por dominio, la brecha identificada, el mapeo a partes del programa y un plan de estudio semanal de 3–6 meses.

Criterio de aceptación: los 8 dominios están cubiertos, cada uno tiene autoevaluación y plan, el mapeo a partes es coherente, y el plan prioriza las brechas mayores con fechas concretas.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"Respondo como técnico"	El CISSP pide mentalidad de gestión; elige la respuesta de riesgo/negocio.
"Memorizo sin entender"	El CAT castiga el memorismo; comprende los principios.
"No cubro todos los dominios"	Estudio desbalanceado; usa la matriz de brechas para equilibrar.
"Aprobé pero no me certifican"	Falta endorsement; necesitas 5 años de experiencia.
"Me confunden due care/diligence"	Concepto sutil; due diligence investiga, due care actúa.

Preguntas frecuentes

 **¿Necesito experiencia para presentarme?** Puedes examinarte sin ella, pero para certificarte necesitas 5 años en 2+ dominios (o 4 con una titulación/certificación aprobada).

? **¿Cuánto tiempo de estudio?** Con base técnica del programa, 3–6 meses enfocado en la mentalidad de gestión y los dominios débiles.

? **¿Es un examen técnico?** No en el sentido de comandos. Evalúa comprensión conceptual y toma de decisiones de riesgo.

? **¿Qué dominio pesa más?** D1 (Seguridad y gestión de riesgos), en torno al 15%. Domínalo bien.

Referencias

- (ISC)² CISSP: <https://www.isc2.org/certifications/cissp>
- CISSP Exam Outline (dominios y pesos): <https://www.isc2.org/certifications/cissp/cissp-certification-exam-outline>
- Chapple, Stewart, Gibson, *CISSP Official Study Guide* (Sybex).
- NIST SP 800-53 (controles): <https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final>
- ISO/IEC 27001: <https://www.iso.org/standard/27001>

Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.

Clase anterior

Clase 303 — Capstone: laboratorio completo de pentest

Siguiente clase

Clase 305 — Capstone: operación Red Team end-to-end